CHAPTER 16 — REFERENCE ARCHITECTURE

Multi-Cloud Enterprise Security

Tracing the complete lifecycle of a cloud-native application through integrated security controls

SECURITY DOMAINS

Identity · Pipeline · Runtime · Data · SecOps · Compliance · Integration

AWS (Primary) · Azure (Secondary) · On-Premises (Legacy)

PRIMARY CLOUD
Amazon Web Services (EKS, S3, KMS, GuardDuty)

SECONDARY CLOUD
Microsoft Azure (AKS, Key Vault, Defender)

ON-PREMISES
Legacy Systems & Sensitive Data Processing

APPLICATION LIFECYCLE →

01 Identity Architecture

"Identity is the new perimeter"

Human Identity

Microsoft Entra ID (Central IdP)
Authoritative source · OIDC federation

Multi-Factor Authentication
Required for all cloud environment access

JIT Access Platform
Time-limited · Role-specific · Approval workflows

⊘ Zero Standing Privileges
No permanent admin access in production
Credentials auto-expire after session

Workload Identity

SPIFFE / SPIRE
Cryptographic identity · SVIDs for all workloads

SPIRE Node Attestation
Pod-spec-based identity verification per node

Istio Service Mesh mTLS
SVID-based mutual TLS between all services

AWS: IRSA
IAM Roles for Service Accounts

Azure: Workload ID
Managed identity federation

Federation Flow

Entra ID (IdP)

OIDC → AWS IAM
OIDC → Azure AD
SAML → On-Prem LDAP

Consistent Policy Enforcement
Single identity → recognized across all environments
SSO · Centralized lifecycle · Unified audit trail

02 Development & Deployment Pipeline

"The line between disorder and order lies in logistics"

① CODE COMMIT	② CONTAINER BUILD	③ IMAGE SIGNING	④ IaC VALIDATION	⑤ STAGING DEPLOY	⑥ PRODUCTION
SAST scanning	Base image validation	Cosign signing	Terraform + Checkov	Integration testing	Admission controller
Secret detection	Dockerfile linting	Org signing keys	OPA policy evaluation	DAST scanning	Signature verification
Dependency analysis	Vuln scan + SBOM gen	Signature stored in registry	Drift detection	Load testing	Pod security standards
GATE: Block on critical	GATE: Fail on crit/high	GATE: Reject unsigned	GATE: Block violations	GATE: All tests pass	GATE: Reject non-compliant

PIPELINE PROPERTIES

Ephemeral runners · Signed Git commits · Branch protection · External secrets · SBOM attestation chain · SLSA provenance · Min permissions

▸ ~40 microservices · Containerized on Kubernetes · Serverless event-driven pipelines · Financial services regulated ◂

03 Runtime Security Architecture

Production — EKS (AWS) & AKS (Azure)

Kubernetes Security Controls

Istio Service Mesh
- ✓ Mutual TLS all service-to-service
- ✓ Fine-grained authZ policies
- ✓ Traffic observability
- ✓ Lateral movement detection
- ✓ Encrypted east-west traffic

Network Policies
- ✓ Default-deny posture
- ✓ Explicit allow per path
- ✓ Namespace isolation
- ✓ Egress restrictions
- ✓ CNI-enforced (Calico/Cilium)

Restricted Pod Security Standard
Non-root · Drop capabilities · RO root FS · Restricted vols · No privilege

Admission Controllers
Validate image signatures · Enforce pod security · Inject sidecars · Reject non-compliant workloads

Runtime Monitoring Stack

Falco — Container Runtime
- ▸ Anomalous process execution
- ▸ Unexpected file access
- ▸ Suspicious network connections
- ▸ Container escape detection
- ▸ Behavioral profiling baseline

Cloud Provider Services
AWS GuardDuty · Azure Defender
- ▸ IAM anomaly detection
- ▸ Crypto mining detection
- ▸ Unusual API patterns

Automated Incident Response (seconds)

Container Compromised
Isolate → Snapshot → Extract logs → Replace

Credential Compromised
Revoke → Kill sessions → Analyze access logs

Image Compromised
Quarantine in registry → Roll back → Alert teams

04 Data Protection Architecture

DATA CLASSIFICATION

Public	Internal	Confidential	Restricted
Provider encryption	CMK encryption	CMK + DLP	CMK + Column enc + DLP

Encryption Architecture
- ✓ Customer-managed keys (AWS KMS + Azure Key Vault)
- ✓ Separate keys per classification tier
- ✓ Column-level encryption (Restricted PII)
- ✓ TLS 1.3 in transit (mesh + LB enforced)

Data Loss Prevention
- ✓ Monitor Confidential + Restricted movement
- ✓ VPC egress controls (approved endpoints only)
- ✓ Database activity monitoring (Restricted)
- ✓ Block Public Access (org level)

Key Management

AWS KMS
CMK · Auto-rotation

Azure Key Vault
CMK · HSM-backed

Key access policies per service identity
Automated rotation · Deletion safeguards · Audit logging

05 Security Operations & Monitoring

"Know thy enemy and know yourself"

TELEMETRY AGGREGATION

CloudTrail / Activity Log
Cloud provider audit

K8s Audit Logs
Cluster operations

Container Runtime Events
falco + mesh telemetry

Application Logs
Distributed traces

VPC Flow Logs
Network patterns

Identity Events
AuthN / AuthZ decisions

Cloud-Native SIEM Platform
Centralized detection · Correlation · Investigation — across AWS, Azure, and On-Premises

Detection Framework
Rules mapped to MITRE ATT&CK Cloud Matrix
Regular coverage reviews · Gap identification · Behavioral analytics

Threat Intelligence
Cloud-specific TTPs · Credential abuse patterns · Resource hijacking
Data exfiltration behaviors · Impossible travel · First-time resource access

06 Compliance & Governance Architecture

"Discipline and organization are the backbone of an army"

Multi-Account Landing Zone

Production	Staging	Development	Shared Svc	Logging	Security
Restricted	Pre-production	Sandbox	Infrastructure	Centralized	Controls

Preventive Guardrails (SCPs + Management Group Policies)
Cannot disable logging · Cannot create public buckets · Cannot deploy in unapproved regions · Cannot modify security controls

Detective Guardrails (Continuous Assessment)
Config drift detection · Non-compliant resource alerting · Automated remediation of critical findings

Continuous Compliance

SOC 2 · PCI DSS · Data Privacy · ISO 27001

- ✓ Real-time config assessment against all frameworks
- ✓ Compliance dashboards (current status)
- ✓ Automated evidence collection packages
- ✓ Quarterly audit support (minimal manual effort)

Cloud Center of Excellence — Standards · Guidance · Security Champions

LIFECYCLE INTEGRATION

Security is not a layer added on top — it is an integral property of the infrastructure itself.
Identity ↔ Pipeline ↔ Runtime ↔ Data ↔ Monitoring ↔ Compliance — each control reinforces the others.
From the first line of code committed to a repository through the decommissioning of the infrastructure it runs on.